
Cybersecurity and privacy maturity assessment and strengthening for digital health information systems



World Health
Organization

European Region

Cybersecurity and privacy maturity assessment and strengthening for digital health information systems



**World Health
Organization**

European Region

Abstract

Digital health aims to enhance patient outcomes and reduce the burden on health-care providers, including doctors, nurses and family caregivers, by leveraging digital technologies. These technologies encompass health-care providers' information systems, cloud computing, mobile apps, web applications, connected medical devices, digital therapeutics, application processing interface services and artificial intelligence/machine learning applications. Operating within a regulatory and cybersecurity-challenged environment, health information systems face threats such as ransomware attacks on hospitals. As digital health services grow, assessing the security and privacy risks of these technologies becomes crucial for developing cost-effective, prioritized risk-mitigation strategies. This guide focuses on cybersecurity and privacy risk assessments in digital health, as tailored to the WHO European Region. It provides a framework for technical audiences to develop risk assessment specifications suited to the unique needs and goals of their organizations and countries in order to comply with country-specific cybersecurity and privacy regulations. The assessment questionnaire that forms part of the assessment methodology is also available in the form of a Microsoft Excel spreadsheet and is published as a separate web annex.

Keywords

CYBERSECURITY, DIGITAL HEALTH, INFORMATION SYSTEMS, RISK ASSESSMENT

Document number: WHO/EURO:2025-11827-51599-78854 (PDF)

© World Health Organization 2025

Some rights reserved. This work is available under the Creative Commons Attribution-NonCommercial-ShareAlike 3.0 IGO licence (CC BY-NC-SA 3.0 IGO; <https://creativecommons.org/licenses/by-nc-sa/3.0/igo>).

Under the terms of this licence, you may copy, redistribute and adapt the work for non-commercial purposes, provided the work is appropriately cited, as indicated below. In any use of this work, there should be no suggestion that WHO endorses any specific organization, products or services. The use of the WHO logo is not permitted. If you adapt the work, then you must license your work under the same or equivalent Creative Commons licence. If you create a translation of this work, you should add the following disclaimer along with the suggested citation: "This translation was not created by the World Health Organization (WHO). WHO is not responsible for the content or accuracy of this translation. The original English edition shall be the binding and authentic edition: Cybersecurity and privacy maturity assessment and strengthening for digital health information systems. Copenhagen: WHO Regional Office for Europe; 2025".

Any mediation relating to disputes arising under the licence shall be conducted in accordance with the mediation rules of the World Intellectual Property Organization (<http://www.wipo.int/amc/en/mediation/rules/>).

Suggested citation. Cybersecurity and privacy maturity assessment and strengthening for digital health information systems. Copenhagen: WHO Regional Office for Europe; 2025. Licence: [CC BY-NC-SA 3.0 IGO](#).

Cataloguing-in-Publication (CIP) data. CIP data are available at <http://apps.who.int/iris>.

Sales, rights and licensing. To purchase WHO publications, see <http://apps.who.int/bookorders>. To submit requests for commercial use and queries on rights and licensing, see <https://www.who.int/about/policies/publishing/copyright>

Third-party materials. If you wish to reuse material from this work that is attributed to a third party, such as tables, figures or images, it is your responsibility to determine whether permission is needed for that reuse and to obtain permission from the copyright holder. The risk of claims resulting from infringement of any third-party-owned component in the work rests solely with the user.

General disclaimers. The designations employed and the presentation of the material in this publication do not imply the expression of any opinion whatsoever on the part of WHO concerning the legal status of any country, territory, city or area or of its authorities, or concerning the delimitation of its frontiers or boundaries. Dotted and dashed lines on maps represent approximate border lines for which there may not yet be full agreement.

The mention of specific companies or of certain manufacturers' products does not imply that they are endorsed or recommended by WHO in preference to others of a similar nature that are not mentioned. Errors and omissions excepted, the names of proprietary products are distinguished by initial capital letters.

All reasonable precautions have been taken by WHO to verify the information contained in this publication. However, the published material is being distributed without warranty of any kind, either expressed or implied. The responsibility for the interpretation and use of the material lies with the reader. In no event shall WHO be liable for damages arising from its use.

Contents

Acknowledgements	iv
Abbreviations	v
Glossary	vi
1. Introduction	1
2. Security and privacy maturity assessment	2
2.1 Common approaches to a security and privacy risk assessment	2
2.2 Why privacy is essential in digital health	3
2.3 Interrelationship between security and privacy	3
2.4 Typical risk scenarios in digital health	4
3. Cybersecurity assessment methodology for digital health information systems	5
3.1 Cybersecurity assessment components	6
3.2 Standards and frameworks	7
3.3 Development of the assessment report	7
References	9
Annex 1. Assessment questionnaire/checklist	11
Annex 2. Security and privacy maturity assessment summary and score sheet	29

Acknowledgements

The development of this document was coordinated by the Data, Evidence and Digital Health Unit of the Division of Country Health Policies and Systems, WHO Regional Office for Europe. It was initially drafted by Hayk Mkrtchyan (Consultant to the WHO Europe, Copenhagen, Denmark, from November 2022 to December 2022) and Suren Ohanov (Consultants to the WHO Europe, Copenhagen, Denmark, from November 2022 to December 2022) with technical oversight from John Hobbie (Consultant to the WHO Europe, Copenhagen, Denmark, Nov-2022), and then upgraded by Karapet Davtyan (Technical Officer, Data, Evidence and Digital Health Unit, Division of Country Health Policies and Systems, WHO Regional Office for Europe) and Danny Lieberman (Consultant to the WHO Europe, Copenhagen, Denmark, October 2024), with strategic guidance from Natasha Azzopardi-Muscat (Director, Division of Country Health Policies and Systems, WHO Regional Office for Europe) and David Novillo Ortiz (Regional Adviser and Unite Head, Data, Evidence and Digital Health Unit, Division of Country Health Policies and Systems, WHO Regional Office for Europe). Karapet Davtyan and David Novillo Ortiz initiated the project and provided technical advice and coordination throughout the development and production process.

The following WHO and external experts contributed to the development of this document by giving valuable feedback or applying the tool in different settings. WHO experts were Natschja Ratanaprayul (Department of Digital Health and Innovations, WHO headquarters); and Keyrellous Adib, Helen Caton-Peters, Stefania Davia, Ryan Alistair Dos Santos, Clayton Hamilton, Marge Reinap, Roman Spataru, Tyrone Reden Sy and Marieke Verschuuren (Data, Evidence and Digital Health Unit, Division of Country Health Policies and Systems, WHO Regional Office for Europe). External experts were Armine Arzumanyan (Lecturer, American University of Armenia, Yerevan, Armenia), Mher Beglaryan (Consultant to the WHO Europe, Copenhagen, Denmark, April 2023), Johnathan Coleman (Principal, Security Risk Solutions, Mount Pleasant, United States of America), Jerome de Barros (Directorate-General for Food and Health Safety, European Commission, Brussels, Belgium), Konstantin Hyppönen (Programme Officer, European Commission, Brussels, Belgium), Kamau Mwangi (Consultant in Digital Health Technologies and Infrastructure, IntelliSOFT Consulting Limited, Nairobi, Kenya), Nelly Nyaga (Head of Strategy and Technical Delivery, IntelliSOFT Consulting Limited, Nairobi, Kenya), Andrew Pattison (Head of GRC Consultancy Europe, IT Governance Ltd, Ely, United Kingdom), Vahagn Sargsyan (Consultant to the WHO Europe, Copenhagen, Denmark, from Jan 2024 to Apr 2024), Eric Sutherland (Senior Health Economist, Organisation for Economic Co-operation and Development, Paris, France) and Leanne N. Torgersen (Doctoral candidate, Trier University, Germany).

The tool was used in Georgia in 2023 and in Armenia in 2024, and then presented at several international conferences and revised based on feedback and lessons learned. WHO thanks staff of the country offices in Armenia and Georgia, the Ministry of Health of Armenia and the Ministry of Internally Displaced Persons from the Occupied Territories, Labour, Health and Social Affairs of Georgia for collaboration and supporting the opportunity to apply the tool.

This publication has been produced with the financial assistance of the European Union, and the United States Agency for International Development. The contents of this publication are the sole responsibility of WHO and can in no way be taken to reflect the views of these organizations.

For further information please contact the Data, Evidence and Digital Health unit (euhiudata@who.int).



Abbreviations

CSF	(National Institute of Standards and Technology) Cybersecurity Framework
d-HIS	digital health information system
GDPR	General Data Protection Regulation
IEC	International Electrotechnical Commission
ISO	International Organization for Standardization
NIST	National Institute of Standards and Technology
SP	Special Publication

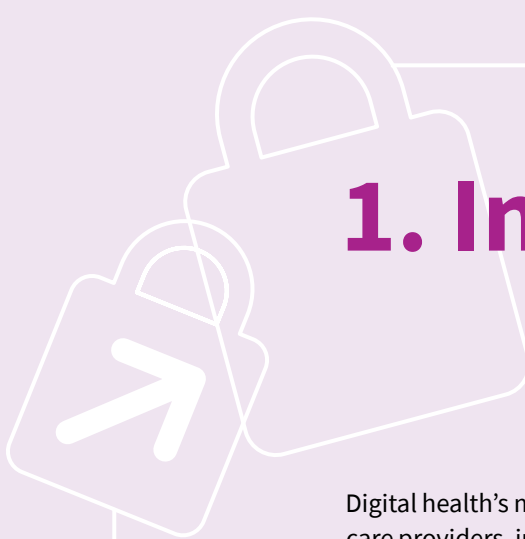
Glossary

The following terms are widely used in the field of cybersecurity and privacy management. See the accompanying references for definitions.

Assessment report	Commonly included in cybersecurity literature and methodologies, such as International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 27001 (<i>Information security, cybersecurity and privacy protection – information security management systems – requirements</i>) (1).
Availability, confidentiality	Two components of the CIA triad (confidentiality, integrity and availability), a foundational model in cybersecurity (2,3).
Cyber incident, cyber threat, cybersecurity	Defined in many security standards, including National Institute of Standards and Technology (NIST) Special Publication (SP) 800-61 (<i>Computer security incident handling guide</i>) (4) and ISO/IEC 27032 (<i>Cybersecurity: guidelines for internet security</i>) (5).
Cybersecurity maturity	Defined by various maturity models, such as the Capability Maturity Model Integration and ISO standards (6,7).
General Data Protection Regulation	Regulation 2016/679 of the European Union (8).
ISO/IEC 27000 family, ISO/IEC 27001	International standards for security and privacy management systems (1,3).
NIST Cybersecurity Framework	A framework designed to improve critical infrastructure cybersecurity (9).
Penetration testing	Defined by many security standards and methodologies (10).
Risk management	Established in ISO 31000 and NIST frameworks (11,12).
Security controls	Often referred to in NIST SP 800-53 (<i>Security and privacy controls for information systems and organizations</i>) (2) and ISO/IEC 27002 (<i>Information security, cybersecurity and privacy protection – information security controls</i>) (13).
Vulnerability	Defined in multiple security contexts, often in relation to vulnerability management and penetration testing (12,13).

References

1. Information security, cybersecurity and privacy protection – information security management systems – requirements, third edition. Geneva: International Organization for Standardization; 2022 (ISO/IEC 27001:2022; <https://www.iso.org/standard/27001>).
2. Security and privacy controls for information systems and organizations. Gaithersburg (MD): National Institute of Standards and Technology; 2020 (NIST SP 800-53 Rev. 5; <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>).
3. ISO/IEC 27000 family. Information security management [website]. International Organization for Standardization; 2024 (<https://www.iso.org/standard/iso-iec-27000-family>).
4. Computer security incident handling guide. Gaithersburg (MD): National Institute of Standards and Technology; 2012 (NIST SP 800-61 Rev. 2; <https://csrc.nist.gov/pubs/sp/800/61/r2/final>).
5. Cybersecurity: guidelines for internet security. Geneva: International Organization for Standardization; 2023 (ISO/IEC 27032:2023; <https://www.iso.org/standard/76070.html>).
6. CMMI for development, version 1.3. Pittsburgh (PA): Software Engineering Institute; 2010 (<https://doi.10.1184/R1/6572342.v1>).
7. Information technology – security techniques – systems security engineering – capability maturity model® (SSE-CMM®). Geneva: International Organization for Standardization; 2008 (ISO/IEC 21827:2008; <https://www.iso.org/standard/44716.html>).
8. European Union. Regulation 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). Off J Eur Union. 2016;L119:1–88 (<https://eur-lex.europa.eu/eli/reg/2016/679/oj>).
9. The NIST cybersecurity framework (CSF) 2.0. Gaithersburg (MD): National Institute of Standards and Technology; 2024 (<https://www.nist.gov/cyberframework>).
10. Technical guide to information security testing and assessment. Gaithersburg (MD): National Institute of Standards and Technology; 2020 (NIST SP 800-115; <https://doi.org/10.6028/NIST.SP.800-115>).
11. Risk management. Geneva: International Organization for Standardization; 2018 (ISO 31000; <https://www.iso.org/iso-31000-risk-management.html>).
12. Guide for conducting risk assessments. Gaithersburg (MD): National Institute of Standards and Technology; 2020 (NIST SP 800-30 Rev. 1; <https://doi.org/10.6028/NIST.SP.800-30r1>).
13. Information security, cybersecurity and privacy protection – information security controls. Geneva: International Organization for Standardization; 2022 (ISO/IEC 27002:2022; <https://www.iso.org/standard/75652.html>).



1. Introduction

Digital health's mission is to improve patient outcomes and reduce the load on health-care providers, including doctors, nurses, and family caregivers. These are recognized as priority areas of focus by WHO and are reflected in the flagship Empowerment through Digital Health initiative of the *European programme of work 2020–2025: united action for better health (1,2)*, which aims to leverage digital technologies to improve health and well-being across the WHO European Region. As part of this flagship initiative, the Regional digital health action plan for the WHO European Region 2023–2030 emphasizes the need to raise awareness and provide practical guidance on cybersecurity risk management and privacy-enhancing technologies that includes data privacy, security and the ethical use of new digital technologies (3–5). This document supports the flagship's objectives of ensuring that digital health solutions are trustworthy, ethical, equitable and sustainable, and that they adhere to the highest standards of quality and safety.

This document describes a security and privacy maturity assessment methodology tailored for digital health systems in the WHO European Region to help to ensure three critical aspects:

- access to digital health services for patients and providers to ensure that digital health systems are available and accessible when needed, supporting continuous care and timely medical interventions – this includes evaluating system reliability, scalability and response times;
- privacy for individual patients and providers by safeguarding personal and medical information to maintain confidentiality and trust, in compliance with the General Data Protection Regulation (GDPR) (6) and other relevant privacy regulations – this includes measures for data encryption, anonymization and secure data-sharing protocols; and
- governance to support the digital health mission by establishing a robust governance life cycle that encompasses data quality, patient safety, treatment efficacy, security, privacy, regulatory compliance and ongoing risk management – effective governance ensures accountability, transparency and continuous improvement.

2. Security and privacy maturity assessment



The security and privacy maturity assessment (often shortened to cybersecurity assessment or risk assessment) process should follow the country's policies (local, national and global) based on the location of the organization. The cybersecurity assessment should follow regulations, standards and best practices such as the following.

- Ensure compliance with GDPR for all aspects of personal data handling and privacy (7).
- Implement a privacy management system based on International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 27701 standards (8) – ISO/IEC 27701 is closely aligned with the GDPR and supports compliance with GDPR requirements.
- Utilize the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) (9) for a high-level cybersecurity strategy and the NIST Special Publication (SP) 800-53 (10) standard for detailed security and privacy controls.

By combining these approaches, you can create a robust security and privacy programme tailored to your regulatory environment while leveraging globally recognized standards for security and privacy management and technical controls.

2.1 Common approaches to a security and privacy risk assessment

There are three common approaches or methods to conduct a risk assessment.

- Testing: the process of exercising one or more assessment objects under specified conditions to compare actual and expected behaviours. This helps to identify vulnerabilities and weaknesses in the system.
- Examination: the process of checking, inspecting, reviewing, observing, studying or analysing one or more assessment objects to facilitate understanding, achieve clarification or obtain evidence. Examination methods help to ensure compliance with policies and standards.

- Interviews: the process of conducting discussions with individuals or groups within an organization to facilitate understanding, achieve clarification or identify the location of evidence. Interviews provide insight into the effectiveness of security controls and help to identify areas in need of improvement.

Assessment results are used to support the determination of security control effectiveness over time, ensuring the ongoing protection of digital health systems.

By addressing these aspects, this methodology aims to create a secure and privacy-compliant digital health environment that supports the broader mission of improving patient care and operational efficiency.

2.2 Why privacy is essential in digital health

In the context of digital health systems, discussing security (or cybersecurity) without considering privacy is possible but incomplete. This is why.

Privacy focuses on:

- patient rights – ensuring that patients have control over their personal and health information;
- data handling – governing how personal data are collected, used, shared and stored; and
- regulatory compliance – adhering to laws and regulations such as GDPR that protect personal information.

2.3 Interrelationship between security and privacy

- Data protection: security measures protect data confidentiality, integrity and availability, which are foundational to privacy.
- Regulatory compliance: privacy regulations often mandate specific security controls to protect personal data.
- Trust and confidentiality: protecting privacy builds patient trust and ensures that sensitive health information is handled with care.

2.4 Typical risk scenarios in digital health

- Security without privacy:
 - encryption – encrypting patient data ensures confidentiality and integrity but, if the data are used or shared without proper consent, then privacy is compromised; and
 - access controls – implementing strict access controls protects data from unauthorized access but does not address how data are collected or shared.
- Privacy without security:
 - consent management – patients provide consent for data use, but if there are no strong security measures, the data could be breached; and
 - data minimization – collecting the minimal data necessary for treatment respects privacy but, without encryption, the data remain vulnerable.

While it is possible to discuss security or cybersecurity without delving into privacy, in the context of digital health systems, this approach is incomplete. Privacy considerations are integral to a comprehensive security strategy. Both aspects are interdependent and crucial for protecting sensitive health information and maintaining patient trust. Therefore, we suggest an integrated approach for a security and privacy maturity assessment that includes:

- a security and privacy risk assessment – combining security and privacy assessments ensures robust protection and compliance;
- holistic policies – developing policies that address both security measures and privacy rights; and
- continuous monitoring – regularly updating and monitoring both security controls and privacy practices to adapt to new threats and regulatory changes.

By integrating both security and privacy into the risk assessment, digital health systems can sustain a secure and trustworthy environment for patients and health-care providers.



3. Cybersecurity assessment methodology for digital health information systems

The assessment approach is based on the methodology of the health information system assessment described in the *Support tool to strengthen health information systems: guidance for health information system assessment and strategy development (11)*. This tool provides a comprehensive framework for assessing the strengths and weaknesses of health information systems and developing strategies for improvement, and is also applicable for a security and privacy assessment. Following this methodology, the cybersecurity assessment is guided by a questionnaire/checklist (Annex 1). The checklist forms the basis of the cybersecurity assessment and can be adapted according to the needs, levels and preferences of the assessment. The tool provides an overview of the security status of an entire digital health information system (d-HIS). It includes a set of standardized questions to enable information-gathering about the given settings to assess whether (i) the privacy, confidentiality and security standards of d-HIS are in place and (ii) the d-HIS system is protected throughout the service delivery and data management. It also provides the minimum list of controls that should be required to secure d-HIS to an authority-approved level of security. The controls presented in the assessment tool may be subjected to a formalized d-HIS health check or penetration test to provide evidence of their adequacy and effectiveness. It is also important to emphasize that the cybersecurity assessment based on the tool should be implemented by a qualified assessor, who should follow the checklist to ensure that it covers the minimum key areas of security and privacy.

3.1 Cybersecurity assessment components

A comprehensive cybersecurity assessment has various components to ensure the robustness and effectiveness of an organization's risk controls. This section outlines the main components of a cybersecurity assessment, encompassing both the review and testing methodologies.

A cybersecurity assessment must include the following two main components:

- review and gap analysis (security audits) is essential for evaluating the current state of security within an organization and should cover the following key areas:
 - governance and policy – assess the adequacy and effectiveness of security governance structures and policies governing security and privacy practices;
 - data management life cycle – review the processes and controls in place for managing data throughout the life cycle, from creation to disposal;
 - transmission security – evaluate the security measures implemented to protect data during transmission, including encryption and secure communication protocols;
 - data disposal – assess the procedures for securely disposing of sensitive data to prevent unauthorized access or disclosure;
 - monitoring – review the effectiveness of monitoring systems and processes for detecting and responding to security incidents in a timely manner; and
 - user behaviour – evaluate user awareness, training programmes and adherence to security policies to mitigate risks associated with insider threats;
- security test (penetration testing) involves simulating real-world attacks to identify vulnerabilities and weaknesses in an organization's systems and infrastructure, and commonly include:
 - network vulnerability tests – identify vulnerabilities in network devices, systems and configurations that could be exploited by attackers;
 - network penetration tests – attempt to gain unauthorized access to network resources to assess the effectiveness of security controls and defences;
 - web application penetration – assess the security of web applications by identifying vulnerabilities such as injection flaws, authentication bypass and insecure direct object references;
 - social engineering tests – evaluate the susceptibility of employees to social engineering attacks, such as phishing and pretexting;
 - security configuration – review the configuration settings of systems, devices and applications to ensure they adhere to security best practices and standards; and
 - operational test – evaluate the operational security of systems and processes, including incident response procedures, access controls and logging mechanisms.

Common penetration testing methodologies and standards that can be used as guidance depending on the testing environment are as follows:

- penetration testing execution standard – a comprehensive framework that defines the stages and processes involved in conducting penetration tests;
- the *Open source security testing methodology manual (12)* – a methodology for assessing and improving the security of information systems and networks;
- the *Open Web Application Security Project Web security testing guide (13)* – guidance for assessing the security of web applications, focusing on common vulnerabilities and attack vectors; and

- NIST SP 800-115 – guidelines for conducting security and privacy assessments (14), including penetration testing and vulnerability scanning and assessing the security posture of information systems and networks, tailored to organizational requirements and objectives.

3.2 Standards and frameworks

Standards and frameworks form something of a virtuous circle with laws and market expectations because they represent different (positive and negative) ways of incentivizing the use of the best practices. Cybersecurity assessment as a discipline and practice has been driven by standards and frameworks across the whole range of data protection needs.

When conducting a security and privacy maturity assessment for digital health, the following standards should be taken into account:

- ISO/IEC 27701 for a privacy management system (8,15,16);
- NIST CSF (9) and NIST SP 800 (17) for technical implementation – the NIST CSF for a high-level cybersecurity framework and the NIST SP 800 series (in particular, NIST SP 800-53 (10) and NIST SP 800-171 (18)) for detailed technical controls and risk management practice; and
- GDPR, a regulation in European Union law on data protection and privacy (6).

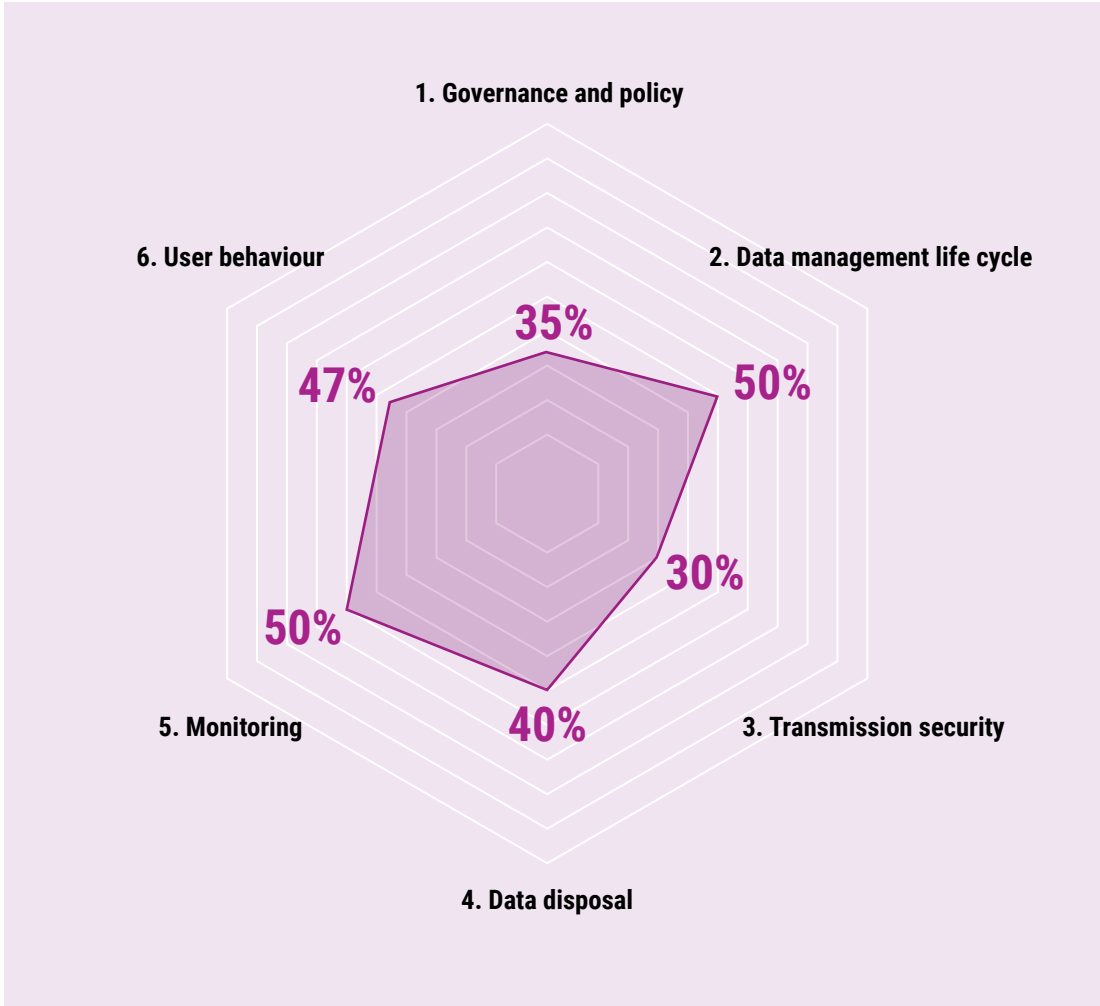
3.3 Development of the assessment report

This is guidance for a security and privacy maturity assessment. The cybersecurity assessment may be done at site, organization or country level according to needs. The assessment result is a report summarizing the current situation, including the assessment maturity score sheet (Annex 2) and recommendations for improvement of the d-HIS security and privacy posture in the short, medium and long term. As well as the score, the maturity scoring template can include a description of the situation under each theme. The following scoring system is applied:

- score of 4 – the situation in the country or given setting is comparable with full maturity;
- score of 3 – many elements of a cybersecurity system with full maturity are in place but some work is still needed;
- score of 2 – some elements of a cybersecurity system with full maturity are in place but substantial work is still needed; and
- score of 1 – the situation in the country is still very far from full maturity.

The results of maturity scoring can be summarized based on the core components of the maturity evaluation chart template. Fig. 1 shows an example that is also available in the Microsoft Excel spreadsheet in the web annex¹.

Fig. 1. Example of a cybersecurity maturity evaluation chart



¹ Cybersecurity and privacy maturity assessment and strengthening for digital health information systems: web annex: assessment instrument. World Health Organization. Regional Office for Europe; 2025 (<https://iris.who.int/handle/10665/380839>, accessed 24 March 2025). License: CC BY-NC-SA 3.0 IGO

References²

1. European Programme of Work 2020–2025: United Action for Better Health. Copenhagen: WHO Regional Office for Europe; 2021 (<https://iris.who.int/handle/10665/339209>). Licence: CC BY-NC-SA 3.0 IGO.
2. Empowerment through digital health [website]. WHO Regional Office for Europe; 2024 (<https://www.who.int/europe/initiatives/empowerment-through-digital-health>).
3. Seventy-second Regional Committee for Europe: Tel Aviv, 12–14 September 2022: Regional digital health action plan for the WHO European Region 2023–2030. Copenhagen: WHO Regional Office for Europe; 2022 (<https://iris.who.int/handle/10665/360950>).
4. Sutherland E, Keelara R, Eisele S, Haugrud J. Fast-track on digital security in health. Paris: OECD Publishing; 2023 (OECD Health Working Papers No. 164; <https://doi.org/10.1787/c3357f9f-en>).
5. OECD policy framework on digital security: cybersecurity for prosperity. Paris: OECD Publishing; 2022 (<https://doi.org/10.1787/a69df866-en>).
6. European Union. Regulation 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). Off J Eur Union. 2016;L119:1–88 (<https://eur-lex.europa.eu/eli/reg/2016/679/oj>).
7. Complete guide to GDPR compliance [website]. European Union; 2024 (<https://gdpr.eu/>).
8. ISO/IEC 27701:2019. Security techniques – extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management: requirements and guidelines. Geneva: International Organization for Standardization; 2019 (<https://www.iso.org/standard/71670.html>).
9. The NIST cybersecurity framework (CSF) 2.0. Gaithersburg (MD): National Institute of Standards and Technology; 2024 (<https://www.nist.gov/cyberframework>).
10. Security and privacy controls for information systems and organizations. Gaithersburg (MD): National Institute of Standards and Technology; 2020 (NIST SP 800-53 Rev. 5; <https://doi.org/10.6028/NIST.SP.800-53r5>).
11. Support tool to strengthen health information systems: guidance for health information system assessment and strategy development, second edition. Copenhagen: WHO Regional Office for Europe; 2024 (<https://iris.who.int/handle/10665/376978>). License: CC BY-NC-SA 3.0 IGO.
12. Open source security testing methodology manual, third edition. Barcelona: Institute for Security and Open Methodologies; 2010 (<https://www.isecom.org/OSSTMM.3.pdf>).
13. OWASP web security testing guide, version 4.2. Wilmington (DE): Open Worldwide Application Security Project Foundation; 2020 (<https://owasp.org/www-project-web-security-testing-guide/>).

2 All references were accessed 02 October 2024.

14. Technical guide to information security testing and assessment. Gaithersburg (MD): National Institute of Standards and Technology; 2020 (NIST SP 800-115; <https://doi.org/10.6028/NIST.SP.800-115>).
15. ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection – information security management systems – requirements, edition 3. Geneva: International Organization for Standardization; 2022 (<https://www.iso.org/standard/27001>).
16. ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection – information security controls, edition 3. Geneva: International Organization for Standardization; 2022 (<https://www.iso.org/standard/75652.html>).
17. NIST Special Publication 800 series: general information [website]. National Institute of Standards and Technology; 2024 (<https://www.nist.gov/itl/publications-0/nist-special-publication-800-series-general-information>).
18. Protecting controlled unclassified information in nonfederal systems and organizations. Gaithersburg (MD): National Institute of Standards and Technology; 2024 (NIST SP 800-171 Rev. 3; <https://csrc.nist.gov/pubs/sp/800/171/r3/final>).

Annex 1. Assessment questionnaire/ checklist ¹

Table A1.1 shows the assessment questionnaire/checklist.

Table A1.1. Assessment questionnaire/checklist.

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
1. Governance and policy				
1.1	Do national and local policies, guidelines or laws exist that cover the security and privacy of d-HIS data, including management of sensitive data?	If local or national laws or policies exist that provide guidance for the security and privacy of d-HIS data, then the site must comply with the governing laws	Review organizational policies that implement local and/or state laws pertaining to the security and privacy of d-HIS data	
1.2	Do you have written guidelines and/or SOPs, if applicable?	Sites are expected to follow and maintain local SOPs pertaining to local and state guidelines or best business practices	Review all guidelines and SOPs for validity towards computer and d-HIS security. Also check to ensure that SOPs are updated at least annually	
1.3	What areas of the data life cycle does the country policy cover? Please specify: • collection • storage • backup • use • transmission • release • disposal • breach investigation • training	The organization is expected to follow the country policies covering data life-cycle management. The site should also create a local policy to further outline their methods for meeting the government requirement	Validate whether the organization is following the country's guidance in their own data life-cycle management policy	

¹ Cybersecurity and privacy maturity assessment and strengthening for digital health information systems: web annex: assessment instrument. World Health Organization. Regional Office for Europe; 2025 (<https://iris.who.int/handle/10665/380839>, accessed 24 March 2025). License: CC BY-NC-SA 3.0 IGO

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
1.4	Is there a written policy or document that covers roles and access for all people with authorized access to PII?	Sites are expected to follow an RBAC model and implement a least-privileged and separation of duties model	Review accounts and documentation to ensure that separation of duties are in effect. Employees with elevated access and privileges should be appointed by memorandum. Cross-reference the documentation with the actual RBAC of personnel	
1.5	Does the site maintain a written policy or document that covers their SOPs or standard methods that must be followed when accessing PII?	The organization should draft a policy that requires a specific set of standards of actions that must be met before allowing access to PII	Validate the local policy or documentation that requires methods or standards for accessing PII. The document must clearly outline the specific requirements for access	
1.6	Which uses of PII are covered by your local guidelines on the security and privacy of data? For example, who can access PII and under what conditions?	The organization should have guidelines pertaining to the specific cases for PII use and for when and how PII is collected	Validate the local policy or documentation that requires methods or standards for how PII is collected	
1.7	Are there written SOPs that explain roles and responsibilities of employees for security and privacy?	Staff are expected to follow set policies and guidelines for security and privacy. The organization should provide a set of procedures and responsibilities that employees are bound to. The descriptions of security and privacy could be formatted as an acceptable use policy that is signed by employees before using a computer	Validate the existence of local policy or guidance that governs the responsibilities of all staff members or employees. A document should outline specific requirements for following these guidelines	
1.8	Is there a written guideline for managing security breaches?	Sites are expected to create and implement an incident response plan. This guide will provide a step-by-step approach for responding to and mitigating security breaches. It will also contain a point of contact list for reporting the incident	Validate the existence of a policy or SOP governing the organization's incident response plan. The document itself could be drafted in the form of an incident response plan but needs to clarify the specific steps to be taken during and after a security breach	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
1.9	Are risk assessments mandated under the data security and privacy policy?	Risk assessments provide a valuable metric for strategic decisions within the organization and allow for risk acceptance based upon the results of the risk assessment	Review the organizational security policy for references to and guidance on the implementation and use of risk assessments	
1.10	Does your organization have a policy or SOP related to the usage of removable media such as USB devices?	The organization should have a policy or SOP pertaining to the usage and restriction of USB devices. USB and removable media are a vital link to data exfiltration and the introduction of viruses	Review the organization's SOP or policy pertaining to the usage and restriction of removable media	
1.11	What policies and procedures are in place to guide the organization's response to cybersecurity incidents?	The defined process and policies for escalating a detected threat to the appropriate personnel are in place	Verify escalation processes by reviewing documentation, interviewing key personnel, and evaluating incident and/or simulation reports	
1.12	Can you describe the processes and contacts in place for collaborating with key health-care stakeholders and organizations to ensure strong cybersecurity and privacy, and how these are utilized during a cybersecurity incident?	There is a good cooperation with key health-care stakeholders and organizations for ensuring strong cybersecurity and privacy in health care. Organizations know who to contact during a cybersecurity incident to get support and collaborate across health sectors to prevent the spread of threats	Check availability and review collaboration frameworks, communication channels and incident response plans with key health-care stakeholders	
2. Data management life cycle				
2.1 Data capture and storage				
2.1.1	Do you keep only the necessary amount of data on the device by exclusively collecting information that is needed to meet the objectives of the given d-HIS or clinical research?	Sites are expected to collect only pertinent information required to meet the project objectives. Any other data that are collected during a project but not required should be disposed of in accordance with the organization's data disposal policy	Review the organization's data disposal policy for comparative analysis against specific projects and the data collected for those projects	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
2.1.2	Is encryption used to protect sensitive data at rest in personal devices and servers? If yes, please specify the algorithms	Sensitive data at rest should be encrypted. Software such as BitLocker for Windows can provide encryption on personal computers and removable media in order to mitigate data loss due to lost physical devices or exfiltration by attackers. Where applicable, data encryption on servers should be implemented using robust algorithms, complemented by strong access controls, network security and physical security measures to ensure comprehensive protection of sensitive data	Inspect and validate the organization's standard encryption software and ensure that it is installed and functional on computers, laptops and servers. Verify that data at rest are encrypted using appropriate algorithms	
2.1.3	Do the data collection methods capture the origin of how, when and by whom the data were collected, modified or deleted to protect against improper modification (falsification) or destruction?	The organization should ensure that it is using software or procedures to monitor data access and modification. This feature is extremely important in the event of unauthorized access to or modification of sensitive data	Review the audit logs for collection methods to ensure the organization is properly collecting specific metrics such as how, when and by whom data are modified or deleted	
2.1.4	Is access restricted to the files containing keys, which are used to encrypt and decrypt sensitive data?	From a security perspective, it is mandatory to use user identification and password or a lock and key to ensure that access to files containing encryption keys is strictly controlled and monitored. Regular audits are used to ensure that only authorized personnel have access	For physical filing cabinets that store sensitive data, check to ensure that they are locked. For files stored on the network, check permissions to ensure that they are locked down and accessible by authorized personnel only. Check whether regular audits are performed	
2.1.5	Is the organizational d-HIS data backed up and, if so, how often?	The organization should create and maintain a local policy or procedure that outlines specific guidance for data backups and data retention measures. Often, state or government standards will dictate the length of retention	Review organizational documentation for references to backing up data and backup frequency. Validate where the data resides and its most current state	
2.1.6	Where are backup copies stored?	Backups of sensitive data should be kept on specified storage systems/servers and not on the host. Backup hard drives can also be stored off site in authorized storage locations	Review the storage location used for backup data and the integrity of the data	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
2.1.7	Are backup data encrypted?	Data should be encrypted when they remain static on a device. Software such as BitLocker for Windows can provide encryption on computers and removable media. Data at rest provide substantial security against data exfiltration or spillage	Inspect and validate the organization's standard encryption software and ensure that it is installed and functional on servers that host backup data	
2.1.8	Are organizational data periodically migrated to newer backup media as technology changes and newer methods of storage are introduced?	A good practice for data storage is to periodically move all stored data to newer technology as it presents itself. This does come with a cost, so a risk analysis should be conducted	Review the storage location and life-cycle management of the hardware in which the data reside	
2.1.9	Are there organizational plans and procedures for restoring systems and data after a cybersecurity attack for recovery?	Have a comprehensive organizational plan and procedures in place to swiftly restore systems and data after a cybersecurity attack to ensure efficient recovery and minimal disruption	Check for staff knowledge and availability of the recovery plan and procedures after a cybersecurity attack	
2.2 Authorization and access controls				
2.2.1	Are all staff required to have a user identifier and password to gain access to a computer?	Each employee should be required to have an individual account to access machine and network resources. This action will help to track cyber incidents and enforce non-repudiation	Review organizational policies and SOPs regarding account creation and maintenance. Inspect accounts created for individuals. Can interview employees for validation	
2.2.2	What type of user identifiers are used?	Organizations should set standards for user identifiers. One of the best identifier methods would be to use the person's "first name.middle initial.last name" as the identifier. This method will help with account auditing during security incidents	Review organizational documentation and account creation policies to ensure the site is using a standard method to create identifiers	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
2.2.3	Are biometrics or other authentication mechanisms and technologies (e.g. fingerprint verification, signature verification, hardware tokens, physical keys (dongles) or smart cards) being used for user identification and authentication?	The usage of two-factor authentication greatly increases security during the authentication of devices or services. While passwords provide a level of security, they are susceptible to brute force, dictionary and rainbow attacks	Review the authentication methods used by employees for accessing systems and applications	
2.2.4	Does the system enforce specifications for passwords, e.g. a combination of a minimum number of lower-case letters, upper-case letters, numbers and special characters?	From a security perspective, the longer and more complex a password requirement is, the more challenging the password is to guess or crack using brute force methods. The organization should maintain a local SOP or policy dictating the minimum password format and requirements	Can review the organization's account creation policy to ensure that passwords are generated to meet the given standard of using a combination of a minimum number of lower-case letters, upper-case letters, numbers and special characters. Can also interview employees to validate enforcement	
2.2.5	Is reusing passwords prohibited for a specific number of generations?	To help to propagate good cyber hygiene and security practices, the organization should restrict password usage to a single generation within 6 months. Re-usage greatly reduces the effectiveness of passwords and creates system vulnerabilities	The organization should maintain technical and administrative controls to limit the re-usage of passwords	
2.2.6	Is the password file encrypted?	Password files should be encrypted to prevent unauthorized or inadvertent access	Review password files on several computers and servers to ensure that they are encrypted	
2.2.7	Are there established procedures to verify the identity of a user prior to providing a new, replacement or temporary password?	The organization should draft an SOP or policy outlining standards for providing replacement or temporary passwords to employees	Review in-place procedures for requirements granting new, replacement or temporary passwords to employees	
2.2.8	Are users required to log out of their device after every session?	Requiring users to log out of their system after usage is a great way to increase the security of these devices by preventing unauthorized access to another person's account and privileges	Interview employees and review security policy to ensure that users are required to log out of their system after each session	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
2.2.9	Do organizational computers implement a screen saver lockout feature?	A screen saver lockout feature helps to prevent unauthorized access of devices by locking the machine after a set amount of time	Validate local or active directory group policy object-setting for screen saver lockout setting	
2.2.10	Do you restrict access to sensitive data using passwords? (e.g. on devices, databases, SD cards, SIM cards, cloud-based storage)	If passwords are used to restrict access to sensitive data, then the passwords must not be identical to user passwords to help to increase security	If sensitive data are not protected by two-factor authentication, then they must be secured using strong passwords. Review the methodology used for accessing such data	
2.2.11	Do you restrict access to sensitive data using two-factor authentication?	To help increase security and prevent unauthorized access to sensitive data, the organization should implement two-factor authentication for specified employees	Review access controls for viewing or editing sensitive data and determine whether two-factor authentication is required	
2.2.12	Are there any frameworks for adding extra access controls and anti-buffer overflow features to the d-HIS system and the applications it hosts?	Good example of this type of frameworks are AppArmor for the Microsoft Windows operating system and Security-Enhanced Linux for NixOS	Review frameworks such as those listed to decide on compliance	
2.3 Data transfer				
2.3.1	What controls are implemented to ensure the security of data during data transfers and data sharing between different systems and/or users? Please specify	There are several controls that can ensure the security of a data transferring procedure, e.g. sender and receiver identity authentication, password protected data file, information encryption, post-transfer verification	Review the organization's SOP and implementation actions for securing data during transfer between different systems and/or users	
2.3.2	What methods are used to transfer d-HIS data between different sites and platforms? Please specify	Consider sharing files via email, FTP, SFTP, file sharing services (Dropbox, Google Drive, iCloud, SharePoint)	Review the organization's SOP and implementation actions for securing data transfer between different sites and platforms	
2.3.3	Are there any authentication methods that are used to authenticate sender and receiver during data transfer?	Public key infrastructure, two-factor authentication	Review the organization's SOP and implementation actions for authenticating the sender and receiver during data transfer	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
3. Transmission security				
3.1 Routers				
3.1.1	Is a router in place that controls information flow between the LAN and the Internet or other networks installed?	The organization should have an installed and managed router that controls information flow paths internally, restricting access to the outside	Review the site network diagrams to ensure the router is physically separating internal and external traffic	
3.1.2	Does the router display a banner indicating ownership of the system and that unauthorized access is prohibited?	The router and network equipment should employ a warning banner displaying ownership and the stipulation for accessing the equipment	Ask an authorized user to log in to the router to review whether a display banner is present with the correct information	
3.1.3	Does the router enable password protection?	Most standard enterprise routers allow the "enable secret password" command that will hash the password, adding a layer of security to the router	Ask an authorized user to log in to the router to review whether the system has enabled password protection/encryption	
3.1.4	Is the router configured to disable all non-essential services, ensuring only the minimum required services are enabled?	To help to safeguard the network, all unnecessary services such as telnet or HTTP services should be removed from router configurations. To help to create a more secure computing environment, the organization should employ trained network administrators that regularly audit network devices	Review the router configuration files to ensure that all unnecessary or unsecure services have been disabled	
3.1.5	Does the router limit access to only named users or user groups through command privilege levels?	Only authorized people should be allowed to access the router via the Secure Shell protocol. Such authorized groups will be designated by their roles	Ask an authorized person to provide the router configuration file showing authorized groups	
3.1.6	Does the router prevent internal IP addresses being revealed?	All local IP addresses should be masked from outside entities. Best practice is to implement network address translation, allowing translation from public to private IP addresses	Review the router configuration file to verify that network address translation has been implemented, with port forwarding where necessary	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
3.1.7	Does the router utilize an access control list that contains information to deny or allow traffic by IP address or group?	All routers should employ access control lists that deny IP addresses and groups of IP addresses that reside outside the organization's security zone	Ask an authorized user to log in to the router to review whether an access control list exists and is updated regularly	
3.1.8	How often are router logs reviewed?	The organization should implement an audit review strategy for their router logs. Most firewall administrators can detect anomalous activity based on their experience	Interview router administrators to determine the frequency of the organization's requirements to review router logs	
3.2 Firewall				
3.2.1	Are firewalls installed and enabled on computers, servers and networks?	All IT systems are expected to have firewalls installed and enabled. Local firewalls help to prevent malicious software propagation and unauthorized actions on end-user devices. Local firewalls also provide a log of deny attempts that is useful during security incidents	Ask an authorized user to log in to each device to review whether the firewall is installed and operational. Also review firewall logs to verify that the firewall is working properly	
3.2.2	Is the firewall software updated regularly?	From a security perspective, it is imperative to keep all IT systems updated to help to mitigate or resolve vulnerabilities and keep the hardware performing efficiently	Review the make and model of the installed firewall, and then reference the software version and compare it with the vendor's recommended version level	
3.2.3	Does the firewall block intrusion attempts?	The organization's firewall is its first line of defence against outside threats. The site is expected to employ and maintain a fully functioning and up-to-date firewall as part of their in-depth defence measures	Ask an authorized user to log in to the firewall to review whether the system is functioning properly and blocking intrusion attempts	
3.2.4	Does the firewall apply a security level in accordance with the type of network?	The organizational firewall should operate within a zone-based firewall model that will break the network out into different security zones. This will allow the ingress and egress of traffic to different control policies	Ask an authorized firewall administrator to display and explain a list of security zones enforced by the firewall	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
3.2.5	Does the firewall specify which software application can access the network or the Internet?	The organization could further their network security by employing an application-level firewall that will restrict which applications can access the Internet. Application whitelisting will be required for this type of security	Consult an authorized network administrator to verify whether an application-layer firewall is installed and to review the process for managing whitelisting policies	
3.2.6	How often are computers, servers and network firewall logs reviewed?	From a security perspective, reviewing computer, firewall and server logs can help to identify malicious activity that might not have been captured by the intrusion detection or prevention system	Review the audit log SOP and interview the employees responsible for reviewing the logs to determine how often they are reviewed	
3.3 Antivirus software				
3.3.1	Is antivirus software installed on desktops, laptops and company servers?	Antivirus software is one of the most important facets of security pertaining to IT devices. This software will help to prevent the installation or execution of malicious software	Check a sample from each listing of desktops, laptops and servers to see whether antivirus software is installed and operational	
3.3.2	How often is antivirus software updated on desktops, laptops and company servers?	To help maintain a secure computing environment, it is imperative to keep the antivirus software updated on all computing devices	Check a sample from each listing of desktops, laptops and servers to see whether antivirus software is installed and up to date	
3.3.3	Is any antivirus software installed and configured to detect and remediate malicious file attachments?	Most enterprise antivirus software can detect and block malicious file attachments. This feature is extremely important if the organization allows files to enter the network from the Internet	Review the antivirus settings to ensure that it has the ability to properly detect malicious file attachments	
3.4 Connectivity				
3.4.1	Are computers permitted to be connected to more than one network?	Allowing computers to optionally connect to more than one network at a given time creates a security risk pertaining to split tunnelling	Ensure that when a LAN cable is plugged into the device that the wireless network interface controller is disabled automatically	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
3.4.2	Is a VPN used for connections?	Use of a VPN greatly increases the security of the network connection by ensuring that all traffic is encrypted	Check the device to see whether a VPN solution is installed and functioning	
3.4.3	Is remote desktop software (e.g. virtual network computing), a remote desktop protocol or a remote framebuffer protocol used for connections?	The use of remote software allows systems to be connected to and managed from geographically separated locations	Check desktops, laptops and servers for remote management software	
3.4.4	Is there built-in encryption on the methods used to connect to other networks?	The implementation of encrypted tunnels between network sites greatly increases the security of all network traffic	Ask an authorized network administrator to provide proof of the encryption methods and protocols used between networks or sites	
4. Data disposal				
4.1	Is a procedure for data disposal outlined in your SOP?	The implementation of an SOP for data disposal will help the organization to scrub their storage facility of data that meets its retirement age and provides direction on disposing of such data	Review whether the organization has and maintains an SOP for data disposal	
4.2	Do you maintain a data retirement schedule for destroying records when they are no longer needed?	The implementation of an SOP for data retirement will help the organization to scrub their storage facility of records that meet their retirement age and provides direction on disposing of such records	Review whether the organization has and maintains an SOP for data retirement	
4.3	Do you maintain documentation of the secure destruction or disposal of records	Sites are expected to maintain a detailed log of destruction and disposal of organizational records pertaining to d-HIS. This list should be catalogued annually and stored accordingly	Review the SOP pertaining to data destruction and/or disposal. The dates and times when data were destroyed are important	
4.4	Does the SOP outline a clearing protocol to overwrite media with non-sensitive data?	All media that are being repurposed should be sanitized by data erasure using a single-pass method, at least	Review the SOP pertaining to data sanitization to ensure that it covers sensitive data clearing	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
4.5	Does the SOP outline a device purging protocol that uses a strong magnetic field to disrupt the recorded magnetic domains?	The organization should enter references in their data disposal SOP pertaining to data degaussing	Review the site's data disposal SOP for references to data degaussing and inspect the device used for degaussing	
4.6	Does the SOP outline a device destruction protocol that involves the disintegration, pulverization, overwriting, melting, incineration or shredding of sensitive data?	Sites should acknowledge and adhere to the importance of hard drive destruction for end-user devices (computers), servers and printers. The hard drives of each of these system contain data remnants and must be securely destroyed to prevent data leakage or theft. The local policy or procedure should outline one of the listed destruction measures. All destroyed hard drives should be catalogued	Review site documentation and SOPs pertaining to device destruction, paying close attention to the last version of the document	
5. Monitoring				
5.1 General overview				
5.1.1	Are d-HIS systems monitored to detect potential or actual security breaches?	The introduction of monitoring solutions or software to detect breaches or malicious attempts could greatly increase the organization's discovery rate	Review the monitoring software that is used to ensure that it is properly monitoring the d-HIS systems	
5.1.2	How often are d-HIS systems monitored?	The greater the frequency of reviewing and monitoring d-HIS systems greatly increases the ability to detect malicious activity or system failure	Interview authorized staff to verify the frequency of system monitoring	
5.1.3	Do you have server utilization monitoring?	The organization should implement server utilization monitoring to help to identify the possibility of hardware or software failure	Ask an authorized administrator to describe their server monitoring procedures and software	
5.1.4	Do you monitor page load time and HTTP/HTTPS error rates?	If the organization hosts a web server, then it should include in its monitoring policy or SOP (ensuring HTTP is not used without HTTPS) references to HTTPS error rates and resolution, which can indicate possible misconfiguration	Review documentation (if it exists) for references to HTTPS error rates and page load times	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
5.1.5	Do you monitor application resources?	It would be prudent for the organization to monitor the resources allocated to applications that either process sensitive data or are used as an asset and hosted on a server	Review application monitoring software to validate whether the organization is compliant	
5.1.6	Do you monitor server caches on a regular basis?	Monitoring the server cache helps the organization to understand the number of resources allocated to the server. Setting the cache to dynamic and providing adequate resources will help in cases of a sudden increase of usage	Can review server cache monitoring by utilizing tools such as System Management Console for Windows	
5.1.7	Do you monitor database performance and key database queries?	Monitoring database performance and query issues is essential for maintaining a stable database environment and ensuring resource availability. The monitoring tool should track latency, errors and any anomalies in query execution across both SQL and NoSQL instances	Validate the software or tools that the organization uses to monitor its databases to ensure consistent usage	
5.2 Risk assessment				
5.2.1	Are risk assessments conducted?	Risk assessments provide a valuable metric for strategic decisions within the organization and allow for risk acceptance based on the results of the risk assessment	Review the organizational security policy for references to and guidance on the implementation and use of risk assessments	
5.2.2	How often are risk assessments performed?	The organization should implement a standard for how often risk assessments are conducted in conjunction with the factors that would initiate the risk assessment	Review the organizational security policy for references to and guidance on the implementation and use of risk assessments	
5.2.3	Do you conduct a system inventory and analyse its intended functions and security requirements during the assessment?	This process helps to define the boundaries of the IT system and identify the resources and data that comprise the system	Review documentation such as the hardware/software list and network diagram to determine the system characterization	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
5.2.4	Do you perform threat identification?	This helps to identify potential threat sources and compiles a threat statement that lists the potential threat sources that are applicable to the IT system being evaluated	Determine whether the organization utilizes scanning software to perform threat identification. Also ensure that scans are performed regularly	
5.2.5	Do you perform vulnerability identification and develop a list of system flaws or weaknesses that could be exploited by the potential threat sources?	The implementation of a solid vulnerability program can help an organization to keep their security posture up to date. Cybersecurity staff are responsible for the identification and cataloging of flaws or weaknesses so that they can be mitigated	Interview the on-site cybersecurity staff and review the vulnerability management documentation for references to mitigation strategies for catalogued vulnerabilities	
5.2.6	Do you review your security and privacy controls before making changes to your systems?	Perform an impact analysis of system changes and consider whether your risk controls will still be effective after the change	Review the organization's change management policy to ensure that the site performs a security and privacy risk impact analysis before making the change	
5.2.7	Do you perform impact analysis and risk determination?	Does the change create new vulnerabilities?	Review the organization's change management policy to ensure that the site performs a security and privacy risk impact analysis before making the change	
5.2.8	Do you have a rollback plan?	The organization should have a risk assessment documented for each change outlining a rollback plan based upon risk. This plan should be documented when the change is approved for implementation	Verify that a rollback plan is part of the change management process	
5.2.9	Do you document the results?	From a process improvement perspective, the organization should perform an AAR for qualitative analysis and documentation. This document will help to align the company's requirements with their strategic objectives	Verify that the change management plan includes an AAR. May ask for examples from the site	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
5.2.10	Are there staff responsible for coordinating the response to a cybersecurity attack, and how are communication protocols established during an incident?	Dedicated staff should be responsible for coordinating cybersecurity attack responses and communication protocols established to effectively manage and mitigate incidents.	Assess key personnel's understanding of response coordination and communication protocols during cybersecurity incidents	
5.2.11	What steps are taken to mitigate and overcome the impact of the cybersecurity attack?	It is expected that the responsible staff can respond to the attack, isolate affected systems, communicate effectively, mitigate the threat, restore operations and review the incident for improvements	Check capacity and response procedures, including system isolation, communication protocols, threat mitigation, restoration and post-incident reviews	
5.3 Audit logs				
5.3.1	Are audit logs created to assist in recording all system transactions?	All audit logs are expected to contain time stamps and pertinent data to correlate system usage and transactions, such as when a user logs on and off, the specific files modified and local account creation	Verify that the audit logs contain system transactions that could be used for an incident investigation	
5.3.2	Are the IP and MAC addresses of the computer from which the action originated recorded in the audit log?	The IP and MAC addresses of each computer should be captured in the audit log for security purposes. Capturing these identifiers will help in resolving security incidents by identifying on which computer the incident has taken place	Check the current audit logs to ensure that they are capturing IP and MAC address identifiers	
5.3.3	Are user identifiers recorded in the audit log?	User identifiers (generally related to the person's name) should be captured in the audit log for security purposes. Capturing user identifiers will help in resolving security incidents by removing the "who" variable	Check the current audit logs to ensure that they are capturing user identifiers	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
5.3.4	Are dates, times and details of key events recorded in the audit log?	Dates, times and DHCP details should be captured in the audit log for security purposes. Capturing these identifiers will help in resolving security incidents by correlating all relevant data in a single location that cannot be modified by users	Check the current audit logs to ensure that they are capturing dates, times and DHCP details	
5.3.5	When files are accessed, is the type of access recorded in the audit log?	A good practice is to ensure that access to specific file types is recorded in the audit log. This event can help to identify the malicious deletion of sensitive files	Validate that the audit logs contain the type of access recorded when files are modified	
5.3.6	Are audit logs stored separately from the rest of the system that they are monitoring?	Best business practice requires all audit logs to be stored separately from host data. Organizations should strive to implement and maintain an audit log or syslog server in which all audit data are correlated for review	Validate that the organization maintains a syslog server and that data are being regularly collected from all systems	
5.3.7	How often is the audit log reviewed, or is there a system for detecting anomalies?	Organizations are expected to review their audit log on a regular basis. Logs should be kept for 1 year, with logs for 3 months readily available for audit. Audit logs should be reviewed regularly by a designated employee on the organizational audit team	Review documentation and interview employees to determine the frequency of their audit log review	
5.3.8	Are audit logs backed up and, if so, how?	The site should create a redundant solution for audit logs. This solution would create a clone of the backup data to ensure that there is not a single point of failure as a result of data corruption or modification	Review the process (automated or manual) through which the organization conducts its backup procedure for audit logs	

No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
6. User behaviour				
6.1	Do you assess the users' level of technology literacy prior to training so as to develop appropriate content?	Organizational training should target both basic and advanced levels of user literacy pertaining to technology when developing training content	Review the site's training policy to validate whether the content level is appropriate for both basic and advanced users	
6.2	Do you train and retrain your d-HIS staff regularly after they start using d-HIS technology?	The organization should require mandatory security and privacy awareness training for new employees within 1 week of the starting week and a minimum of 1–4 times per year for all employees depending on need and ensuring that the training package is updated regularly	Seek evidence of training in training logs including employee and trainer signatures, typically in online training	
6.3	Does your training programme address the importance of data security, privacy and confidentiality?	To help sustain a safe computing environment, the organization should implement a training programme for new and existing employees that covers important topics and facets of data security, privacy, and confidentiality of sensitive organizational information such as commercial contracts	Review the training material to ensure that it includes references to data security, privacy and confidentiality	
6.4	Does your training programme teach users how to use the d-HIS application?	To help sustain a trained and efficient workforce, the organization should implement a training programme for new and existing employees that covers important topics relating to their d-HIS application	Review the training material to ensure that it includes references to the site's d-HIS application	
6.5	Does your training programme teach users how to make passwords secure?	Organizational training programmes should place a strong emphasis on how to create, manage and secure the employee passwords used to access systems	Review the training material to ensure that it includes reference to the importance of making secure passwords	

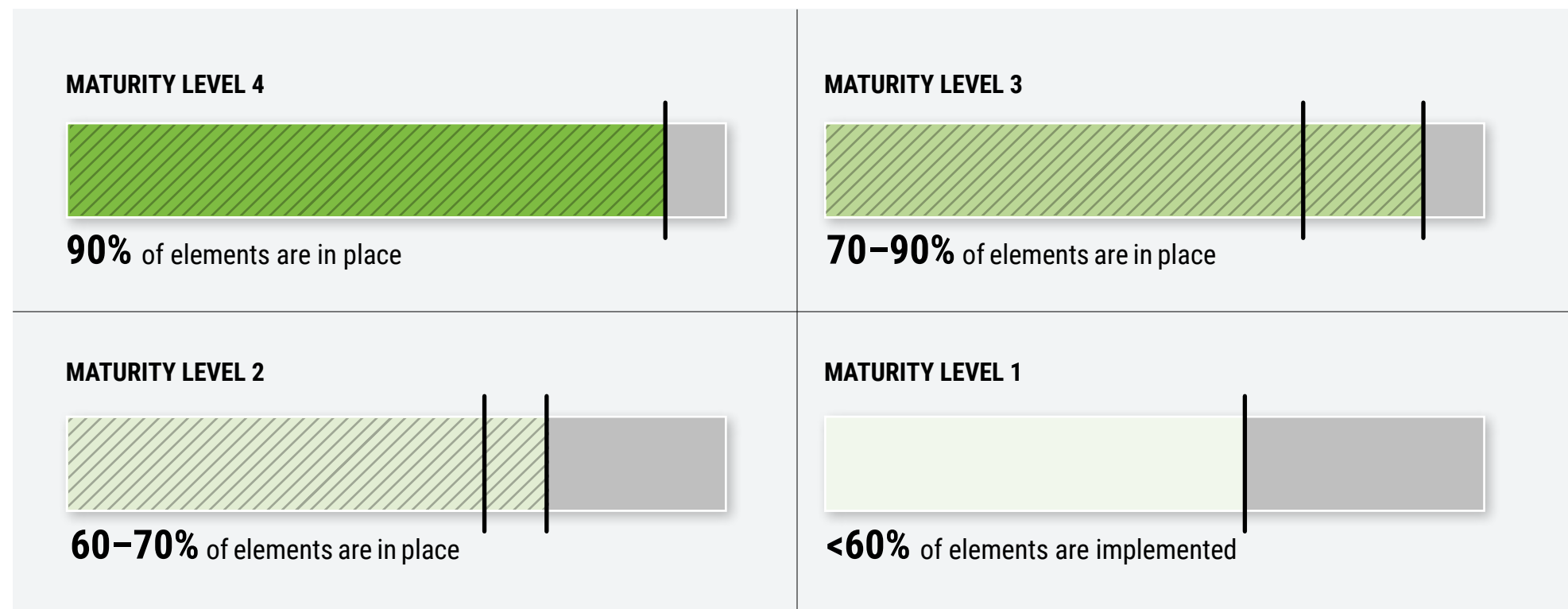
No.	Interview question	Expectations	Testing methodology for assessors	Assessor's comments
6.6	Does your training programme teach users about their roles and responsibilities related to maintaining the security, privacy and confidentiality of sensitive data?	To help sustain a safe computing environment, the organization should implement a training programme for new and existing employees that covers important topics on their roles and responsibilities pertaining to sensitive data, privacy and confidentiality	Review the training material to ensure that it includes reference to sensitive data, privacy and confidentiality	
6.7	Does your training programme teach users how to implement the SOP related to data security, privacy and confidentiality?	The organization's training plan should include references to how the employees or users implement SOPs when dealing with data security, privacy and confidentiality	Review the site's training documentation and look for references to employees' application/implementation of the SOP when working with sensitive data	
6.8	Does your training programme teach users how to avoid common user errors that could affect data security, privacy and confidentiality?	The site training plan should clearly show how to avoid common user errors that could lead to security incidents, e.g. how to react to phishing attempts or what to do when they find a random USB device lying on the floor	Review the site's training documentation and look for references on how employees can avoid general IT errors or mistakes when working in the office setting	
6.9	Are simulated phishing campaigns conducted to monitor and assess the cybersecurity awareness of organization's users? If so, can you provide details of how these campaigns are implemented and evaluated?	Organizations should have regular simulated phishing campaigns and comprehensive training with clear reporting mechanisms, detailed metrics, feedback and improvement, leadership involvement, and integration into policies and procedures	Reviewing the site's simulated phishing policy, activity log and summary reports to identify trends, high-risk areas and opportunities for targeted feedback and training	

AAR: after-action review; d-HIS; digital health information system; DHCP: dynamic host configuration protocol; FTP: file transfer protocol; HTTP: hypertext transfer protocol; HTTPS: hypertext transfer protocol secure; IP: Internet protocol; IT: information technology; LAN: local area network; MAC: media access control; NoSQL: not only structured query language; PII: personally identifiable information; RBAC: role-based access control; SD: secure digital; SFTP: secure file transfer protocol; SIM: subscriber identity module; SOP: standard operating procedure; SQL: structured query language; USB: universal serial bus; VPN: virtual private network.

Annex 2. Security and privacy maturity assessment summary and score sheet

Table A2.1 shows the security and privacy maturity assessment summary and score sheet¹. The scoring system ranks the maturity level of the country/site risk management system according to the findings of the assessor.

Scoring system



¹ Cybersecurity and privacy maturity assessment and strengthening for digital health information systems: web annex: assessment instrument. World Health Organization. Regional Office for Europe; 2025 (<https://iris.who.int/handle/10665/380839>, accessed 24 March 2025). License: CC BY-NC-SA 3.0 IGO

Table A2.1. Security and privacy maturity assessment summary and score sheet.

No.	Description of a risk management system with full maturity	Description of the current situation in the country	Country score	Assessor's comments and recommendations
1. Governance and policy				
1.1	One of the important aspects of governance is the need to align or link an organization's overall goals and objectives with the lower-level security and privacy protection goals and objectives that security professionals help to establish, operate and maintain. Policies are formally prepared, authoritatively issued directions or statements of intent that senior leadership provide to the organization. Some of these describe the organization's strategic goals and objectives. If local laws or policies exist that provide guidance for the security and privacy of d-HIS data and the management of sensitive data, then the site must comply with the governing laws			
1.2	Guidelines provide advisory information and can offer insights drawn from experience and observation. There are not mandates but, rather, recommendations and suggestions. Standards cover a broad range of issues. Some are very broad and strategic (NIST SP 800-37 on risk management, ² ISO/IEC 27000 family), ³ whereas others specify the physical, electrical or other detailed attributes of products, systems, devices etc. Procedures define the explicit, repeatable activities necessary to accomplish a specific task or set of tasks. They can address one-time or infrequent actions and regular occurrences. If local SOPs exist, sites are expected to follow and maintain those pertaining to local and state guidelines or best business practices			
Total				

- 2 Risk management framework for information systems and organizations: a system life cycle approach for security and privacy. Gaithersburg (MD): National Institute of Standards and Technology; 2024 (NIST SP 800-37 Rev. 2; <https://doi.org/10.6028/NIST.SP.800-37r2>, accessed 24 March 2025).
- 3 ISO/IEC 27000 family. Information security management [website]. International Organization for Standardization; 2024 (<https://www.iso.org/standard/iso-iec-27000-family>, accessed 24 March 2025).

No.	Description of a risk management system with full maturity	Description of the current situation in the country	Country score	Assessor's comments and recommendations
2. Data management life cycle				
2.1	The availability of a data life-cycle management strategy ensures that data stay secure and avoid being duplicated. It helps organizations to make sure that they are compliant, as most industries need to have guidelines for proper data retention. The strategy includes a minimum of four stages across the entire data life cycle: data capture, backup and recovery, data management, and data retention and removal. Each stage has its own special role. From a security perspective, the data capture phase is ideal for categorizing data from least sensitive to most sensitive, as well as least important to most important, to make data removal easier in the final phases. In phase 2, these data are then archived in a way that makes them easy to access with complete accuracy. After that, a disaster recovery plan is implemented with a thorough data backup process to ensure that all important records are backed up. The data must be accessible to authorized users. The last phase addresses what happens to data after they have been used, and dictates how long data can be stored and how they are disposed of			
Total				
3. Transmission security: data in motion				
3.1	Security controls are applied to transmissions in order to protect data in motion and mitigate threats of interception, disruption of reception, communications deception and/or derivation of intelligence by the analysis of transmission characteristics such as signal parameters or message externals. Best security practices mandate use of the Secure Shell protocol for secure login and SSL/TLS for data transmission between systems, application programming interface services and browsers and VPNs. SSL VPNs may be implemented in software or hardware firewalls			
Total				

No.	Description of a risk management system with full maturity	Description of the current situation in the country	Country score	Assessor's comments and recommendations
4. Data disposal				
4.1	The implementation of an SOP directed at data disposal will help the organization to scrub their storage for data that meet their retirement age and provides direction on how to dispose of such data. Organizations maintain a detailed log of the destruction and disposal of organizational records pertaining to d-HIS. This list is catalogued annually and stored accordingly. Data classification and categorization directly influence the method by which the data are to be disposed of. Printed data disposal may require cross-cut shredding, as defined by the data owner. Digital data disposal may require employees to use a utility to verify that data have been fully removed from their computers after they erase files containing sensitive data. To address any possible data remanence issues or concerns, the organization should enter references in their data disposal SOP pertaining to data degaussing. All media that are being repurposed should be sanitized utilizing data erasure with at least a single-pass method. After erasing data, the hard drives are destroyed for end-user devices (computers), servers and printers. Each of these system hard drives contain data remnants and must be securely destroyed to prevent data leakage or theft			
Total				
5. Monitoring				
5.1	Security monitoring involves real-time or near-real-time monitoring of the events and activities happening on all important systems at all times with the aim of detecting cyber threats and data breaches. It involves collecting and analysing information to detect suspicious behaviour or unauthorized system changes on the network, defining which types of behaviour should trigger alerts, and acting on alerts as needed			

No.	Description of a risk management system with full maturity	Description of the current situation in the country	Country score	Assessor's comments and recommendations
5.2	Security monitoring is part of the security control plan that is the output from the security and privacy risk assessment performed by the organization. The security and privacy risk assessment is a process that identifies, evaluates and prioritizes risk created by threats that exploit vulnerabilities in assets. After analysing the threat scenarios, a prioritized mitigation plan of controls is implemented for each threat scenario in order to minimize risk impact			
5.3	An audit log is a chronological record of security-relevant data that documents the sequence of activities affecting an operation, procedure, event, file or document. Many organizations use audit logs to detect security breaches, aid recovery processes and prevent unfavourable events from reoccurring. In terms of compliance, health care requires that sensitive information is shared in a secure fashion and only made accessible to authorized people. Audit logs are proof to assessors that you are indeed sharing files securely and complying with privacy laws			
Total				
6. User behaviour				
6.1	One of the most important aspects of ensuring security and privacy is to ensure the technological literacy and awareness of employees. Organizations must create and sustain employee training programmes. Training is ongoing and addresses the importance of data security, privacy and confidentiality. Training programmes teach users about their roles and responsibilities related to handling sensitive data and help them to learn how to implement SOPs related to data security, privacy and confidentiality of sensitive organizational information. Trained staff help to reduce the risk of security and privacy risk			
Total				

d-HIS: digital health information system; IEC: International Electrotechnical Commission; ISO: International Organization for Standardization; NIST: National Institute of Standards and Technology; SOP: standard operating procedure; SP: Special Publication; SSL: secure sockets layer; TLS: transport layer security; VPN: virtual private network.

The WHO Regional Office for Europe

The World Health Organization (WHO) is a specialized agency of the United Nations created in 1948 with the primary responsibility for international health matters and public health. The WHO Regional Office for Europe is one of six regional offices throughout the world, each with its own programme geared to the particular health conditions of the countries it serves.

Member States

Albania	Greece	Portugal
Andorra	Hungary	Republic of Moldova
Armenia	Iceland	Romania
Austria	Ireland	Russian Federation
Azerbaijan	Israel	San Marino
Belarus	Italy	Serbia
Belgium	Kazakhstan	Slovakia
Bosnia and Herzegovina	Kyrgyzstan	Slovenia
Bulgaria	Latvia	Spain
Croatia	Lithuania	Sweden
Cyprus	Luxembourg	Switzerland
Czechia	Malta	Tajikistan
Denmark	Monaco	Türkiye
Estonia	Montenegro	Turkmenistan
Finland	Netherlands (Kingdom of the)	Ukraine
France	North Macedonia	United Kingdom
Georgia	Norway	Uzbekistan
Germany	Poland	

World Health Organization Regional Office for Europe

UN City, Marmorvej 51
DK-2100, Copenhagen Ø, Denmark
Tel: +45 45 33 70 00
Fax: +45 45 33 70 01
Email: euhiudata@who.int
Website: <https://www.who.int/europe>

WHO/EURO:2025-11827-51599-78854 (PDF)